

CO 5 – ASSESMENT TOOL 1

JAVA PROGRAMMING

**APPLICATION-BASED PROBLEM-SOLVING QUESTION
BANK**

NAME: P.V.N. ANISH BABU

REG NO: 192472329

COURSE CODE: CSA0924

COURSE NAME: JAVA PROGRAMMING

SLOT: D

A search page executes a query built by concatenating raw user input into a WHERE clause via a plain Statement, and a tester enters a value designed to always evaluate true. Trace exactly what final SQL string executes, and why it returns every row in the table instead of none.

JAVA CODE

```
import java.sql.*;

public class SQLInjectionDemo {

    public static void main(String[] args) {

        String url = "jdbc:mysql://localhost:3306/company";

        String username = "root";

        String password = "root";

        // Malicious input entered by the tester

        String input = "' OR '1'='1'";

        try {

            Connection con = DriverManager.getConnection(

                url, username, password);

            System.out.println("User Input: " + input);

            System.out.println();
```

```
// =====
```

```
// 1. VULNERABLE CODE - Statement
```

```
// =====
```

```
String sql = "SELECT * FROM customers WHERE name = "  
    + input + "";
```

```
System.out.println("Final SQL Query:");
```

```
System.out.println(sql);
```

```
System.out.println();
```

```
Statement stmt = con.createStatement();
```

```
ResultSet rs = stmt.executeQuery(sql);
```

```
System.out.println("Result using Statement:");
```

```
while (rs.next()) {
```

```
    System.out.println(
```

```
        rs.getInt("id") + " " +
```

```
        rs.getString("name") + " " +
```

```
        rs.getString("city")
```

```
    );
```

```
}
```

```
// =====  
  
// 2. SECURE CODE - PreparedStatement  
  
// =====  
  
String secureSql =  
    "SELECT * FROM customers WHERE name = ?";  
  
PreparedStatement ps =  
    con.prepareStatement(secureSql);  
  
ps.setString(1, input);  
  
ResultSet secureRs = ps.executeQuery();  
  
System.out.println();  
System.out.println("Result using PreparedStatement:");  
  
boolean found = false;  
  
while (secureRs.next()) {  
    found = true;
```

```
        System.out.println(

            secureRs.getInt("id") + " " +

            secureRs.getString("name") + " " +

            secureRs.getString("city")

        );
    }

    if (!found) {

        System.out.println("No matching records found.");

    }

    con.close();

} catch (SQLException e) {

    System.out.println("Database Error: " + e.getMessage());

}

}

}
```

Sample Table

Suppose the customers table contains:

id	name	city
1	Anish	Chennai
2	Rahul	Hyderabad
3	Priya	Bangalore
4	Arjun	Mumbai

Expected Output

User Input: ' OR '1'='1

Final SQL Query:

```
SELECT * FROM customers WHERE name = " OR '1'='1'
```

Result using Statement:

1 Anish Chennai

2 Rahul Hyderabad

3 Priya Bangalore

4 Arjun Mumbai

Result using PreparedStatement:

No matching records found.